

Incident Response Engagement Findings & Detection Report

INC-2026-005 - OS Command Injection & Web Shell

CLIENT

NexaCorp Industries

Employee self-service portal intrusion investigation

Engagement reference INC-2026-005

Target host bru-web-01

Prepared by

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 8 June 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
EXECUTIVE SUMMARY	4
METHODOLOGY	6
INCIDENT TIMELINE	8
TECHNICAL ANALYSIS	9
5.1 OS command injection (ping tool)	9
5.2 Web shell deployment and RCE	10
5.3 Local File Inclusion attempts (failed)	11
5.4 Credential reuse, SSH pivot	12
RISK MATRIX	13
MITRE ATT&CK MAPPING	14
DETECTION ENGINEERING	15
REMEDATION	16
TOOLS AND STANDARDS	17
GLOSSARY AND ACRONYMS	19

Confidentiality Statement

This report documents INC-2026-005 of the BeCode Corp internal cybersecurity training programme, an incident response engagement against a controlled laboratory environment simulating an OS command injection incident on the fictitious organisation NexaCorp's employee portal. No real production system, customer data, or third party was involved. All identities, hostnames and accounts referenced belong to the BeCode training environment.

This document is classified Confidential, do not distribute outside BeCode Corp, under reference BCC-2026 | INC-2026-005. Raw evidence is retained by BeCode Corp and is not redistributed. Publication for portfolio use was authorized by the BeCode lab coach (Thomas B.) on 2026-05-17.

Disclaimer

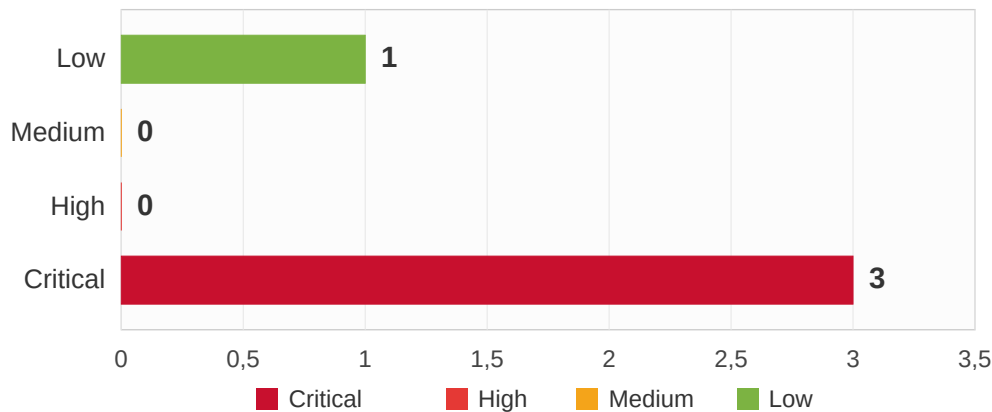
The findings are based on the evidence bundle provided for INC-2026-005 (web access log, network capture, Wazuh alert export, auth log) covering 2026-06-05. Timestamps come from web_access.log and auth.log (real request time) ; Wazuh timestamps reflect SIEM indexing and are not used for the timeline. The methodology follows NIST SP 800-61r2 and the SANS PICERL process. Root vulnerability : OWASP A03:2021 Injection.

Executive Summary

The employee portal bru-web-01 was successfully breached on Friday 5 June 2026, over a capture window of roughly eight hours (08:00 to 15:47). An external attacker (172.16.50.10) abused the diagnostic tools page (a "ping a device" feature) to run system commands directly on the server : OS command injection. The attacker confirmed code execution under the web server account (www-data), read the system accounts file (/etc/passwd), and dropped a hidden web shell that guaranteed repeated access.

A neighbouring feature (the file viewer) was also probed, but those Local File Inclusion attempts all failed : the real data leak went through the command injection, not the file viewer. After taking control through the web shell, the attacker logged into the server over SSH using the valid credentials of an employee (j.martin), gaining persistent interactive access. The root cause is an unfiltered input field that passes commands straight to the OS. Five detection rules were deployed to identify each stage in future.

Findings by Severity Level

**B.**

Overview of findings

Ref	Description	Severity
5.1	OS command injection on the ping tool (RCE under www-data, /etc/passwd read)	CRITICAL
5.2	Web shell /shell.php deployed and used (confirmed RCE, persistence)	CRITICAL
5.3	Local File Inclusion attempts on the file viewer (all failed, no data leaked)	LOW
5.4	Credential reuse: successful SSH pivot as j.martin	CRITICAL

Overview of recommendations

REF	FINDING	SHORT RECOMMENDATION
5.1	Command injection	Remove or rewrite the diagnostic page; never pass user input to a shell; allowlist input.
5.2	Web shell	Remove /var/www/html/shell.php; integrity-scan the webroot; least privilege for www-data.
5.4	SSH reuse	Rotate j.martin; block 172.16.50.10; audit SSH sessions, keys and cron under the account.
Detection	Coverage	Deploy the five Suricata rules (section Detection Engineering), scoped to the segment.

Methodology

A. Procedure

The investigation follows NIST SP 800-61r2 and the SANS PICERL process, mapping every finding to MITRE ATT&CK Enterprise v15. It is an investigation lab with a detection-engineering phase (Suricata rules validated by offline replay).

01. Web access log analysis

- Identify the attacker among subnet scanners by request pattern
- Separate the exec, fi and shell.php request zones



02. PCAP response analysis

- Follow HTTP streams to recover injected commands and responses
- Confirm RCE (www-data) and the /etc/passwd leak source



03. LFI verdict and consequence

- Compare response sizes to prove the LFI failed (3868 vs 5510)
- Confirm the SSH pivot in auth.log



04. Detection engineering

- Author five Suricata rules across request and response buffers
- Validate by deterministic offline replay



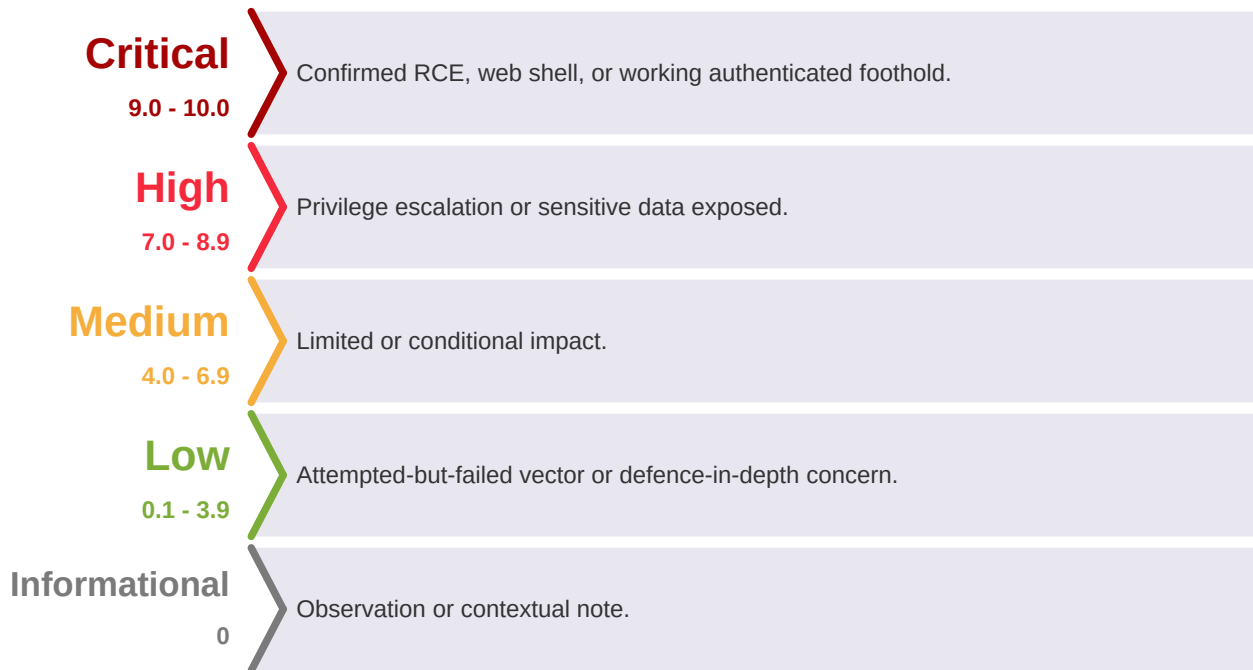
05. Consolidation and reporting

- Map findings to MITRE ATT&CK;
- Consolidate IOCs and remediation



B. Severity ratings

Severity uses CVSS v3.1 as foundation with engagement-contextual elevation : confirmed RCE, a deployed web shell and a working SSH foothold are rated Critical ; a probed-but-failed vector (LFI) is rated Low because no data left through it.



Incident Timeline

Timestamps from web_access.log and auth.log (real request time). The intrusion spans ~8 hours, from the 08:00 login to the 15:47 SSH pivot ; the first offensive action (command injection) lands at 11:11, after ~3 hours of access.

<i>Time (Jun 5)</i>	<i>Event</i>	<i>Evidence</i>
08:00:02	Portal authentication (login.php, index.php) via curl	web_access.log
11:11:59	First malicious request: first POST to the ping tool (command injection)	web_access.log
11:53 - 14:54	Further exec POSTs (id, whoami, cat /etc/passwd, ls webroot, uname)	web_access.log + pcap
12:47 - 15:13	LFI probes (etc/passwd, os-release, config.inc.php, access.log): all 3868 bytes, failed	web_access.log
15:34:04	POST exec: web shell drop (shell.php written to webroot)	web_access.log + pcap stream 3054
15:35:40	Web shell usage: GET /shell.php?cmd=id (RCE confirmed, www-data)	web_access.log + pcap stream 3066
15:37:23	GET /shell.php?cmd=ls -la /var/www/html/ (webroot enumeration)	web_access.log + pcap stream 3076
15:47:15 - 15:47:20	SSH Accepted password for j.martin from 172.16.50.10 (x3, successful pivot)	auth.log

Technical Analysis

5.1 OS Command Injection on the ping tool

Severity:

CRITICAL

Finding type:

OS command injection on a public-facing parameter

CVSS v3.1 base score:

9.8 (Critical) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE:

CWE-78 (OS Command Injection)

MITRE ATT&CK:

T1190, T1059 (Command and Scripting Interpreter)

Affected scope:

- bru-web-01, endpoint /dvwa/vulnerabilities/exec/ (POST)
-

Description:

The ping tool passes the ip field to the OS without sanitisation. Seven POST requests between 11:11:59 and 15:34:04 chain a command after the legitimate ping using the ; separator (URL-encoded %3B). The POST bodies are not in the access log, but abnormal variable response sizes and the recovered PCAP streams confirm execution. Injected commands (by follow stream): id, whoami, cat /etc/passwd, ls -la /var/www/html/, uname -a, then the web shell write.

Confirmed leak:

Stream 2251 (cat /etc/passwd) returned the system accounts file in clear, including the root line and j.martin:x:1001:1001. This is the real data leak of the incident (the LFI failed, see 5.3). The j.martin account reused over SSH appears here, so the attacker knew it existed before the pivot.

Evidence:

```
# pcap stream 2251 (POST body) - real /etc/passwd leak via command injection
ip=127.0.0.1;cat /etc/passwd
# response (extract): root:x:0:0 ... j.martin:x:1001:1001
```

5.2 Web shell deployment and confirmed RCE

Severity:

CRITICAL

Finding type:

Web shell (persistence) and remote code execution

CVSS v3.1 base score:

9.8 (Critical) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE:

CWE-78, CWE-434 (Unrestricted Upload / file write)

MITRE ATT&CK:

T1505.003 (Web Shell), T1059

Affected scope:

- bru-web-01, artifact /shell.php

Description:

The final exec POST (stream 3054, 15:34:04) wrote a web shell to the webroot. shell.php does not exist in a standard DVWA install : it was created by the attacker. Two subsequent GET requests to /shell.php?cmd= confirm a working web shell. The response to ?cmd=id (stream 3066) returns uid=33(www-data), proving the shell executes code under the Apache account, not an error page. The second use enumerates the webroot (ls -la /var/www/html/).

Why it matters:

The web shell is a persistence mechanism independent of any credential : a standing remote-code-execution channel into the server until the file is removed.

Evidence:

```
# web shell write (pcap stream 3054, POST body) and usage (access log)
ip=127.0.0.1; (echo a PHP one-liner system() web shell) > /var/www/html/shell.php
GET /shell.php?cmd=id -> uid=33(www-data) gid=33(www-data)
```

5.3 Local File Inclusion attempts (failed)

Severity:

LOW

Finding type:

Local File Inclusion probing (no data disclosed)

CVSS v3.1 base score:

N/A (attempted, no successful disclosure)

CWE:

CWE-22 (Path Traversal)

MITRE ATT&CK:

T1190 (attempted)

Affected scope:

- bru-web-01, endpoint /dvwa/vulnerabilities/fi/?page= (GET)

Description:

Five GET requests probed the file viewer with traversal payloads (etc/passwd, etc/os-release, the DVWA config, the Apache access log for log poisoning). All four traversals returned exactly 3868 bytes, identical to each other and different from the include.php baseline (5510). The viewer served its default/error page every time : no file content was included.

Verdict:

The LFI failed. No data left through this channel. This is the precise distinction of the incident : all system information the attacker obtained came from the command injection (5.1), not the file viewer. The finding is retained as Low because the vector exists and should still be fixed, even though it disclosed nothing.

5.4 Credential reuse, successful SSH pivot

Severity:**CRITICAL**

Finding type:Valid-account access via reused credential

CVSS v3.1 base score:8.8 (Critical) - AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CWE:CWE-522 (Insufficiently Protected Credentials)

MITRE ATT&CK:T1078 (Valid Accounts), T1021.004 (SSH)

Affected scope:

- bru-web-01 (SSH service), account j.martin
-

Description:

At 15:47, about ten minutes after the web shell use, auth.log shows three successful SSH logins (Accepted, not Failed) for j.martin from 172.16.50.10, the same IP as all the web activity. The short successive logins are consistent with a credential-validity test or automation. The credential was the same j.martin password reused from INC-2026-004 ; the account name was confirmed in the /etc/passwd leak (5.1).

Impact:

A persistent interactive foothold on bru-web-01 under a real employee identity, independent of the web shell. This access is the starting point for INC-2026-006.

Evidence:

```
2026-06-05T15:47:15 bru-web-01 sshd[13158]: Accepted password for j.martin from 172.16.50.10
port 44061 ssh2
2026-06-05T15:47:17 ... Accepted password for j.martin ...
2026-06-05T15:47:20 ... Accepted password for j.martin ...
```

Risk Matrix

Each finding plotted by Impact against Likelihood. Upper-right is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				5.2	5.1
High (4)				5.4	
Medium (3)					
Low (2)			5.3		
Very Low (1)					
Critical High Medium Low					

5.1 (command injection), 5.2 (web shell) and 5.4 (SSH foothold) are Critical ; 5.3 (failed LFI) is Low because no data left through it, though the vector should still be fixed.

MITRE ATT&CK Mapping

<i>Finding</i>	<i>Tactic</i>	<i>Technique ID</i>	<i>Technique Name</i>
5.1	Initial Access / Execution	T1190, T1059	Exploit Public-Facing App; Command and Scripting Interpreter
5.1	Credential Access	T1003.008	OS Credential Dumping: /etc/passwd and /etc/shadow
5.2	Persistence	T1505.003	Server Software Component: Web Shell
5.3	Initial Access	T1190	Exploit Public-Facing Application (attempted)
5.4	Initial Access / Lateral Movement	T1078, T1021.004	Valid Accounts; Remote Services: SSH

Framework : MITRE ATT&CK Enterprise v15. Root vulnerability : OWASP A03:2021 Injection.

Detection Engineering

Five Suricata rules were developed, one per distinct stage of the kill chain, and validated against the PCAP in offline mode (suricata -r, deterministic TCP reassembly). Each rule targets a buffer matched to its intent : http.request_body (raw, URL-encoded) for request-side payloads, http.uri (normalised) for web shell usage, and file_data (response body) for response-side detection that proves successful exploitation rather than a mere attempt.

<i>SID</i>	<i>Stage detected</i>	<i>Buffer</i>	<i>Match</i>	<i>Alerts</i>
1000001	System file targeting in the injection	http.request_body	etc in the POST body	1
1000002	Web shell usage	http.uri	shell.php + cmd=	2
1000003	Web shell write	http.request_body	shell.php in the POST body	1
1000004	RCE confirmed (response side)	file_data	www-data in the response	6
1000005	/etc/passwd exfiltration (response side)	file_data	root:x:0:0 in the response	1

All five rules fire. The offline count is the reliable forensic reference (full reassembly, no network timing constraints), unlike live tcpreplay which loses reassembly of large multi-segment responses. Rule 1000002 produces 2 alerts offline (one per real shell request, ?cmd=id and ?cmd=ls) ; the response-side rules (1000004, 1000005) prove successful exploitation, not just an attempt. Rule 1000001 (content etc) is broad and would be tightened to a system-path context in production. The full ruleset and false-positive notes are in the detection/ folder.

Remediation

1. Immediate containment

Remove the web shell /var/www/html/shell.php and integrity-scan the webroot for any other dropped file. Block 172.16.50.10 at the perimeter (firewall / WAF).

2. Rotate the compromised credential

Force a password change for j.martin and audit all SSH sessions from 172.16.50.10 (auth.log, last, journals). Verify no SSH key or cron job was added under the account.

3. Fix the root cause

The diagnostic page passes user input straight to the OS via system(). Remove the features if not business-critical, or rewrite them to never pass user input to a shell : native libraries, strict allowlist file reads, and input validation with no shell metacharacters permitted.

4. Deploy detection

Put the five Suricata rules into production with network variables scoped to the protected segment, tightening rule 1000001 toward a system-path context. Alert the SOC on any match.

5. Baseline hardening

Apply least privilege to www-data (no write access to the webroot in production). Segment the web server from the rest of the internal network. Re-audit bru-web-01 after INC-2026-004 : two distinct injection vulnerabilities on the same host within days call for a full application code review.

Tools and Standards

A. Tools used during the engagement

<i>Category</i>	<i>Tool</i>	<i>Purpose</i>
Log analysis	grep / awk	Separate the attacker from subnet scanners by request pattern
Network capture analysis	tshark / Wireshark	Follow HTTP streams to recover injected commands and responses
Response sizing	awk on response bytes	Prove the LFI failed (identical 3868-byte responses vs 5510 baseline)
Detection engineering	Suricata	Author and validate the five rules by deterministic offline replay
Documentation	VS Code, Markdown	Note-taking and report drafting

B. Standards and frameworks followed

<i>Standard / Framework</i>	<i>Version</i>	<i>Application</i>
NIST SP 800-61r2	2012	Incident handling methodology
SANS PICERL	-	Incident response phases
MITRE ATT&CK Enterprise	v15	Technique mapping
OWASP Top 10	2021	A03:2021 Injection (root vulnerability)
CVSS	v3.1	Severity scoring
CWE	v4.16	Root-cause classification (CWE-78, 434, 22, 522)
Suricata rule syntax	-	Detection rule authoring (SID 1000001-1000005)

Glossary and Acronyms

<i>Acronym</i>	<i>Full Name</i>	<i>Description</i>
RCE	Remote Code Execution	Running attacker-chosen commands on the server
OS command injection	OS Command Injection	Injecting shell commands through unsanitised input (CWE-78)
Web shell	Web Shell	A script left on a server that runs commands sent over HTTP
LFI	Local File Inclusion	Making the app include/read a local file via path traversal (CWE-22)
www-data	Apache service account	The low-privilege user the web server runs as on Debian
DVWA	Damn Vulnerable Web Application	Deliberately vulnerable training web app
SSH	Secure Shell	Encrypted remote-administration protocol
IOC	Indicator of Compromise	Artifact pointing to malicious activity
PCAP	Packet Capture	Captured network traffic
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat behaviour framework
OWASP	Open Worldwide Application Security Project	A03:2021 Injection covers command injection
CWE	Common Weakness Enumeration	Classification of software weaknesses

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-005

Classification: Confidential, do not distribute outside BeCode Corp

Analyst

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi